

Dark Web: De 0 a Experto

Análisis y estudio de la economía underground

Diego Saavedra

2025-12-31

Table of contents

1	Dark Web: De 0 a Experto	13
2	Dark Web: De 0 a Experto	14
2.1	Análisis y estudio de la economía underground	14
2.2	¿Qué aprenderás?	14
2.2.1	Competencias que desarrollarás:	14
2.3	¡Comencemos!	15
3	Sílabo - Dark Web: De 0 a Experto	16
4	Sílabo de la Asignatura	17
4.1	1. Información General	17
4.2	2. Descripción	17
4.3	3. Resultados de Aprendizaje	17
4.3.1	Generales	17
4.3.2	Específicos por Unidad	18
4.4	4. Metodología	19
4.5	5. Evaluación	19
4.5.1	Matriz de Evaluación	19
4.6	6. Bibliografía	20
4.6.1	Básica	20
4.6.2	Complementaria	21
I	Unidad 1: Fundamentos de la Dark Web	22
5	Fundamentos de la Dark Web	23
6	Unidad 1: Fundamentos de la Dark Web	24
6.1	1. Introducción	24
6.1.1	Conexión al contexto	24
6.2	2. Contenido Teórico	24
6.2.1	2.1. La Web, el Deep Web y la Dark Web	24
6.2.2	2.2. Onion Routing Detallado	25

6.2.3	2.3. OPSEC esencial	25
6.2.4	2.4. deepdarkCTI	25
6.3	3. Aplicaciones Prácticas	25
6.3.1	Escenario 1: Verificación de anonimato	25
6.3.2	Escenario 2: Búsqueda de fuentes	25
6.4	3. Aplicaciones Prácticas	26
6.4.1	Escenario 1: Navegando foros ocultos	26
6.4.2	Escenario 2: Investigando precios de exploits	26
6.5	4. Caso de Estudio: El modelo Cyber Kill Chain	26
6.6	5. Errores Comunes	27
6.6.1	Misconception: “Tor hace todo el trabajo de anonimato”	27
6.6.2	Misconception: “La dark web es solo para criminales”	27
6.7	6. Actividades	27
6.7.1	Lecturas Asignadas	27
6.7.2	Ejercicios Prácticos	27
6.7.3	Preguntas de Discusión	28
6.7.4	Auto-Evaluación	28
6.7.5	Preguntas de Verificación	28
6.8	7. Bibliografía	28
6.8.1	Principal	28
6.8.2	Papeles	28
6.8.3	Estándares	28
6.8.4	Digital	29
6.9	8. Tareas Anti-IA	29
6.9.1	Tarea 1: Dibujo manual	29
6.9.2	Tarea 2: Explicación oral	29
7	Laboratorio 1: Introducción a Tor y Whonix	30
8	Laboratorio 1: Introducción a Tor y Whonix	31
8.1	Objetivo	31
8.2	Requisitos previos	31
8.3	Paso 1: Descargar Whonix	31
8.3.1	1.1. Identificar fuentes oficiales	31
8.3.2	1.1. DeepdarkCTI para URLs .onion	32
8.3.3	1.2. Verificar firma GPG	32
8.4	Paso 2: Configurar Whonix Gateway	32
8.4.1	2.1. Crear red host-only	32
8.4.2	2.2. Configurar interfaz	32
8.5	Paso 3: Verificar funcionamiento de Tor	33
8.5.1	3.1. Chequear servicio Tor	33
8.5.2	3.2. Verificar IP pública	33
8.6	Paso 4: Navegador Tor Browser	33
8.6.1	4.1. Configuración segura	33
8.6.2	4.2. Acceso a servicio de prueba	33
8.7	Verificación Final	33

8.8	Rubrica de laboratorio	34
9	Quiz 1: Fundamentos de la Dark Web	35
10	Quiz 1: Fundamentos de la Dark Web	36
10.1	Instrucciones	36
10.2	Preguntas	36
10.2.1	1. Desarrollo (Bloom: Comprender)	36
10.2.2	2. Opción múltiple (Bloom: Recordar)	36
10.2.3	3. Verdadero/Falso (Bloom: Evaluar)	37
10.2.4	4. Análisis (Bloom: Analizar)	37
10.2.5	5. Comando (Bloom: Aplicar)	37
10.2.6	6. Diseño (Bloom: Crear)	37
10.3	Rubrica rápida	37
II	Unidad 2: Acceso Seguro y OPSEC	39
11	Acceso Seguro y OPSEC	40
12	Unidad 2: Acceso Seguro y OPSEC	41
12.1	1. Introducción	41
12.2	2. Contenido Teórico	41
12.2.1	2.1. Principios de OPSEC	41
12.2.2	2.2. Arquitectura Whonix	42
12.2.3	2.3. Herramientas de defensa	42
12.3	3. Aplicaciones Prácticas	42
12.3.1	Escenario: Investigador identificado	42
12.3.2	Escenario: Setup seguro	42
12.4	4. Errores Comunes	42
12.4.1	Misconception: “Whonix es suficiente solito”	42
12.4.2	Misconception: “Puedo usar mi máquina para esto”	42
12.5	5. Actividades	43
12.5.1	Lectura	43
12.5.2	Ejercicios	43
12.6	6. Auto-Evaluación	43
12.7	7. Bibliografía	43
13	Laboratorio 2: Configuración Whonix Avanzada	44
14	Laboratorio 2: Configuración Whonix Avanzada	45
14.1	Objetivo	45
14.2	Paso 1: Configurar firewall host	45
14.2.1	1.1. Reglas iptables	45
14.3	Paso 2: Configurar Whonix Gateway	45
14.3.1	2.1. Editar configuración Tor	45
14.4	Paso 3: Verificar aislamiento	46

14.4.1 3.1. Test de DNS leak	46
14.5 Verificación	46
14.6 Rubrica	46
15 Quiz 2: OPSEC y Whonix	47
16 Quiz 2: OPSEC y Whonix	48
16.1 Preguntas	48
16.1.1 1. Desarrollo	48
16.1.2 2. Opción múltiple	48
16.1.3 3. Verdadero/Falso	48
16.1.4 4. Análisis	48
16.1.5 5. Comando	49
 III Unidad 3: Vulnerabilidades y Exploits	 50
17 Vulnerabilidades, Exploits y Acceso Inicial	51
18 Unidad 3: Vulnerabilidades, Exploits y Acceso Inicial	52
18.1 1. Introducción	52
18.2 2. Contenido Teórico	52
18.2.1 2.1. Initial Access Brokers (IABs)	52
18.2.2 2.2. Checkers vs Brute-Forcers	52
18.2.3 2.3. Exploit Builders	53
18.3 3. Caso de Estudio: TMChecker	53
18.3.1 Análisis técnico	53
18.3.2 Señales de detección	53
18.4 4. Errores Comunes	54
18.4.1 Misconception: “Los exploits son imposibles de usar”	54
18.4.2 Misconception: “Phishing es ineficaz”	54
18.5 5. Actividades	54
18.5.1 Lectura	54
18.5.2 Ejercicios	54
18.6 6. Auto-Evaluación	54
18.7 7. Bibliografía	54
19 Laboratorio 3: Análisis de Credenciales y Checkers	55
20 Laboratorio 3: Análisis de Credenciales y Checkers	56
20.1 Objetivo	56
20.2 Paso 1: Identificar servicios objetivo	56
20.2.1 1.1. Servicios corporativos comunes	56
20.3 Paso 2: Identificar señales de TMChecker	56
20.3.1 2.1. User-Agent estándar	56
20.3.2 2.2. Patrones de login	57
20.4 Paso 3: Identificar en logs	57

20.4.1 3.1. Buscar patrones	57
20.5 Verificación	57
21 Quiz 3: Vulnerabilidades, Exploits y Credenciales	58
22 Quiz 3: Vulnerabilidades, Exploits y Credenciales	59
22.1 Preguntas	59
22.1.1 1. Desarrollo	59
22.1.2 2. Opción múltiple	59
22.1.3 3. Verdadero/Falso	59
22.1.4 4. Análisis	59
22.1.5 5. Comando	60
22.1.6 6. Diseño	60
 IV Unidad 4: Técnicas de Entrega de Malware	 61
23 Técnicas de Entrega de Malware	62
24 Unidad 4: Técnicas de Entrega de Malware	63
24.1 1. Introducción	63
24.2 2. Loaders	63
24.2.1 2.1. Qué es un loader	63
24.2.2 2.2. SmokeLoader (desde 2013)	63
24.2.3 2.3. BunnyLoader	64
24.3 3. Botnets	64
24.3.1 3.1. Mirai Family	64
24.3.2 3.2. CosaNostra Botnet	64
24.4 4. Ejercicios	64
24.5 5. Auto-Evaluación	64
25 Laboratorio 4: Análisis de Loaders	65
26 Laboratorio 4: Análisis de Loaders	66
26.1 Objetivo	66
26.2 Paso 1: SmokeLoader Anti-debug	66
26.2.1 1.1. Chequeo de debugger	66
26.3 Paso 2: BunnyLoader String Obfuscation	66
26.3.1 2.1. Identificar strings encriptadas	66
26.4 Paso 3: Identificar rutas de descarga	67
26.4.1 3.1. URLs ocultas	67
26.5 Verificación	67
27 Quiz 4: Malware Delivery Techniques	68
28 Quiz 4: Malware Delivery Techniques	69
28.0.1 1. Desarrollo	69

28.0.2	2. Opción múltiple	69
28.0.3	3. Verdadero/Falso	69
28.0.4	4. Análisis	69
28.0.5	5. Comando	69
V	Unidad 5: Information Stealers	70
29	Information Stealers	71
30	Unidad 5: Information Stealers	72
30.1	1. Introducción	72
30.2	2. Proceso de un stealer	72
30.2.1	2.1. Victim Download	72
30.2.2	2.2. Data Collection	72
30.2.3	2.3. Exfiltration	73
30.3	3. Caso: Raccoon Stealer	73
30.3.1	Funcionalidad clave	73
30.3.2	Evasion	73
30.4	4. Ejercicios	73
30.5	5. Auto-Evaluación	73
31	Laboratorio 5: Análisis de Information Stealers	74
32	Laboratorio 5: Análisis de Information Stealers	75
32.1	Objetivo	75
32.2	Paso 1: Identificar rutas de datos	75
32.2.1	1.1. Rutas de navegadores	75
32.3	Paso 2: Identificar rutas de cryptowallets	75
32.3.1	2.1. Wallets comunes	75
32.4	Paso 3: Identificar rutas de exfiltración	75
32.4.1	3.1. URLs de C2	75
32.5	Verificación	76
33	Quiz 5: Information Stealers	77
34	Quiz 5: Information Stealers	78
34.0.1	1. Listar	78
34.0.2	2. Explicar	78
34.0.3	3. Analizar	78
34.0.4	4. Identificar	78
34.0.5	5. Comando	78
VI	Unidad 6: Banking Trojans	79
35	Banking Trojans	80

36 Unidad 6: Banking Trojans	81
36.1 1. Introducción	81
36.2 2. Android Banking Trojans	81
36.2.1 2.1. Accessibility API Abuse	81
36.2.2 2.2. Cerberus Overlay	81
36.3 3. Windows Banking Trojans	82
36.3.1 3.1. TrickBot Browser Injection	82
36.3.2 3.2. Cadenas de ataque	82
36.4 4. Mitigaciones	82
36.5 5. Auto-Evaluación	82
37 Laboratorio 6: Banking Trojans Android	83
38 Laboratorio 6: Banking Trojans Android	84
38.1 Objetivo	84
38.2 Paso 1: Identificar permisos	84
38.2.1 1.1. Manifest analysis	84
38.3 Paso 2: Identificar overlays	84
38.3.1 2.1. Overlay code	84
38.4 Verificación	84
39 Quiz 6: Banking Trojans	86
40 Quiz 6: Banking Trojans	87
40.0.1 1. Identificar	87
40.0.2 2. Explicar	87
40.0.3 3. Comparar	87
40.0.4 4. Verificar	87
40.0.5 5. Comando	87
VII Unidad 7: Packers y Crypters	88
41 Packers y Crypters	89
42 Unidad 7: Packers y Crypters	90
42.1 1. Introducción	90
42.2 2. Técnicas de protección	90
42.2.1 2.1. String Obfuscation	90
42.2.2 2.2. Control Flow Obfuscation	90
42.2.3 2.3. Entropy Analysis	90
42.3 3. Proceso de Unpacking	91
42.3.1 3.1. Memory Allocation	91
42.3.2 3.2. UpX Unpacking	91
42.4 4. Ejercicios	91
42.5 5. Auto-Evaluación	91

43 Laboratorio 7: Unpacking de Malware	92
44 Laboratorio 7: Unpacking de Malware	93
44.1 Objetivo	93
44.2 Paso 1: Identificar packer	93
44.2.1 1.1. PEiD o Detect It Easy	93
44.3 Paso 2: Calcular entropy	93
44.3.1 2.1. Análisis de entropía	93
44.4 Paso 3: Unpacking manual	94
44.4.1 3.1. Memory dump	94
44.5 Verificación	94
45 Quiz 7: Packers y Crypters	95
46 Quiz 7: Packers y Crypters	96
46.0.1 1. Definir	96
46.0.2 2. Identificar	96
46.0.3 3. Explicar	96
46.0.4 4. Diferenciar	96
46.0.5 5. Comando	96
 VIII Unidad 8: Frameworks C2	 97
47 Frameworks Command-and-Control	98
48 Unidad 8: Frameworks Command-and-Control	99
48.1 1. Introducción	99
48.2 2. Componentes de un C2	99
48.3 3. Caso: Vermilion Strike vs Cobalt Strike	99
48.3.1 Técnicas de evasión	99
48.4 4. Detección	100
48.4.1 4.1. Tráfico C2	100
48.4.2 4.2. Sliver Detection	100
48.5 5. Auto-Evaluación	100
49 Laboratorio 8: Análisis de Frameworks C2	101
50 Laboratorio 8: Análisis de Frameworks C2	102
50.1 Objetivo	102
50.2 Paso 1: Identificar configuración	102
50.2.1 1.1. Strings sospechosas	102
50.3 Paso 2: Decodificar configuración	102
50.3.1 2.1. XOR decode	102
50.4 Verificación	102
51 Quiz 8: Frameworks C2	104

52 Quiz 8: Frameworks C2	105
52.0.1 1. Identificar	105
52.0.2 2. Explicar	105
52.0.3 3. Analizar	105
52.0.4 4. Verificar	105
52.0.5 5. Comando	105
 IX Unidad 9: Living Off the Land	 106
53 Living Off the Land	107
54 Unidad 9: Living Off the Land	108
54.1 1. Introducción	108
54.2 2. LOLBins comunes	108
54.3 3. Técnicas por fase	108
54.3.1 3.1. Discovery	108
54.3.2 3.2. Privilege Escalation	109
54.3.3 3.3. Lateral Movement	109
54.4 4. Caso: Conti Playbook	109
54.5 5. Mitigaciones	109
54.6 6. Auto-Evaluación	109
 55 Laboratorio 9: Living Off the Land	 110
56 Laboratorio 9: Living Off the Land	111
56.1 Objetivo	111
56.2 Paso 1: Analizar logs de proceso	111
56.2.1 1.1. Sysmon events	111
56.3 Paso 2: Identificar patrones sospechosos	111
56.3.1 2.1. PowerShell encoded	111
56.4 Paso 3: WMI abuse detection	112
56.4.1 3.1. WMIC patterns	112
56.5 Verificación	112
 57 Quiz 9: Living Off the Land	 113
58 Quiz 9: Living Off the Land	114
58.0.1 1. Listar	114
58.0.2 2. Explicar	114
58.0.3 3. Identificar	114
58.0.4 4. Verificar	114
58.0.5 5. Comando	114

X	Unidad 10: Windows Ransomware	115
59	Windows Ransomware	116
60	Unidad 10: Windows Ransomware	117
60.1	1. Introducción	117
60.2	2. Historia del ransomware	117
60.3	3. Técnicas del locker	117
60.3.1	3.1. Generación de claves	117
60.3.2	3.2. Evasión de recuperación	118
60.4	4. Caso: REvil/Sodinokibi	118
60.4.1	Versión temprana (2019)	118
60.4.2	Versión mejorada (2020+)	118
60.5	5. Snaffler para reconocimiento	118
60.6	6. Decryptores	118
60.6.1	Ejemplo: Babuk leak	119
60.7	5. Decryptores	119
60.8	6. Auto-Evaluación	119
61	Laboratorio 10: Análisis de Ransomware Windows	120
62	Laboratorio 10: Análisis de Ransomware Windows	121
62.1	Objetivo	121
62.2	Paso 1: Identificar rutas excluidas	121
62.2.1	1.1. Whitelist strings	121
62.3	Paso 2: Identificar rutas de eliminación de backups	121
62.3.1	2.1. Shadow copy deletion	121
62.4	Paso 3: Identificar rutas de exfiltración	121
62.4.1	3.1. Note drop	121
62.5	Verificación	122
63	Quiz 10: Windows Ransomware	123
64	Quiz 10: Windows Ransomware	124
64.0.1	1. Identificar	124
64.0.2	2. Explicar	124
64.0.3	3. Analizar	124
64.0.4	4. Verificar	124
64.0.5	5. Comando	124
XI	Unidad 11: Linux y ESXi Ransomware	125
65	Linux y ESXi Ransomware	126
66	Unidad 11: Linux y ESXi Ransomware	127
66.1	1. Introducción	127

66.2	2. ESXi Hypervisor	127
66.2.1	2.1. Ventajas para atacantes	127
66.2.2	2.2. REvil ESXi variant	127
66.2.3	3 fases del ataque:	127
66.2.4	Whitelist específico:	128
66.3	3. ALPHV Rust-based	128
66.3.1	3.1. Configuración	128
66.3.2	3.2. Proceso	128
66.3.3	3.3. Ventajas Rust	128
66.4	3. ALPHV Rust-based	128
66.4.1	Características	128
66.5	4. Detección en Linux	129
66.5.1	Syslog monitoring	129
66.5.2	Process monitoring	129
66.6	5. Auto-Evaluación	129
67	Laboratorio 11: Análisis de Ransomware Linux/ESXi	130
68	Laboratorio 11: Análisis de Ransomware Linux/ESXi	131
68.1	Objetivo	131
68.2	Paso 1: Identificar paths de ESXi	131
68.2.1	1.1. Configuración típica	131
68.3	Paso 2: Identificar rutas excluidas	131
68.3.1	2.1. Whitelist Linux	131
68.4	Paso 3: Identificar procesos atacados	131
68.4.1	3.1. Process killing	131
68.5	Verificación	132
69	Quiz 11: Linux y ESXi Ransomware	133
70	Quiz 11: Linux y ESXi Ransomware	134
70.0.1	1. Identificar	134
70.0.2	2. Explicar	134
70.0.3	3. Analizar	134
70.0.4	4. Verificar	134
70.0.5	5. Comando	134
XII	Unidad 12: Lecciones de la Economía Underground	135
71	Lecciones de la Economía Underground	136
72	Unidad 12: Lecciones de la Economía Underground	137
72.1	1. Introducción	137
72.2	2. Modelo económico del underground	137
72.2.1	2.1. Reactive Development	137
72.2.2	2.2. Rebranding	137

72.3	3. Lowered Barriers to Entry	137
72.3.1	3.1. DIY malware kits	137
72.3.2	3.2. Tutoriales publicados	138
72.4	4. Inteligencia Artificial	138
72.5	5. Futuro de la ciberseguridad	138
72.5.1	Tendencias	138
72.5.2	Estrategias defensivas	138
72.6	6. Proyecto Final	138
72.7	7. Auto-Evaluación	138
73	Laboratorio 12: Proyecto Final	139
74	Laboratorio 12: Proyecto Final	140
74.1	Objetivo	140
74.2	Paso 1: Selección de caso	140
74.2.1	1.1. Fuentes permitidas	140
74.3	Paso 2: Análisis del caso	140
74.3.1	2.1. Kill chain mapping	140
74.4	Paso 3: Recomendaciones	141
74.4.1	3.1. Mitigación por fase	141
74.5	Entregable	141
74.6	Rubrica	141
75	Quiz 12: Lecciones de la Economía Underground	142
76	Quiz 12: Lecciones de la Economía Underground	143
76.0.1	1. Definir	143
76.0.2	2. Explicar	143
76.0.3	3. Analizar	143
76.0.4	4. Proponer	143
76.0.5	5. Reflexionar	143

Chapter 1

Dark Web: De 0 a Experto

Análisis y estudio de la economía underground

Chapter 2

Dark Web: De 0 a Experto

2.1 Análisis y estudio de la economía underground

Información del Curso

- **Duración:** 12 semanas (3 créditos)
- **Modalidad:** Presencial / Virtual sincrónico
- **Requisitos previos:** Conocimientos básicos de redes, sistemas operativos y programación
- **Herramientas:** Tor Browser, Whonix, entornos virtualizados aislados
- **Advertencia:** Todo el material se basa en análisis de fuentes abiertas. El acceso a herramientas reales requiere entornos controlados y con autorización legal.

2.2 ¿Qué aprenderás?

En este curso explorarás el ecosistema oculto de la dark web desde una perspectiva técnica y de investigación, entendiendo cómo funcionan las herramientas maliciosas, cómo se comercializan y cómo defenderse de ellas.

2.2.1 Competencias que desarrollarás:

1. **Navegar de forma segura** por la dark web usando Tor y Whonix
2. **Analizar herramientas del underground** como loaders, stealers y ransomware
3. **Entender el modelo económico** de la cibercriminalidad organizada

4. **Aplicar técnicas de reverse engineering** a malware real
5. **Desarrollar estrategias de defensa** basadas en conocimiento de amenazas

2.3 ¡Comencemos!

“Conocer al enemigo es la mejor forma de prepararse para la batalla.”
— Sun Tzu, adaptado al contexto de ciberseguridad

Chapter 3

Sílabo - Dark Web: De 0 a Experto

Chapter 4

Sílabo de la Asignatura

4.1 1. Información General

Campo	Valor
Carrera	Ingeniería en Sistemas/Computación
Código	DW101
Créditos	3
Horas Teoría	2 h/semana
Horas Práctica	2 h/semana
Horas Autónomo	3 h/semana
Prerrequisitos	Redes y Sistemas (RR001)
Docente	Diego Saavedra — dsaavedra@unl.edu.ec
Office Hours	Miércoles 14:00-16:00

4.2 2. Descripción

Este curso explora el ecosistema de la dark web desde una perspectiva técnica de investigación en ciberseguridad. Los estudiantes analizarán herramientas maliciosas, entenderán el modelo económico de la cibercriminalidad y desarrollarán habilidades para defender organizaciones contra amenazas emergentes. El enfoque combina teoría, análisis técnico y laboratorios controlados.

4.3 3. Resultados de Aprendizaje

4.3.1 Generales

Código	Resultado	Nivel Bloom
OG1	Analizar las técnicas de acceso a la dark web utilizando Tor y Whonix, verificando la protección de identidad	Analizar
OG2	Configurar entornos de análisis de malware utilizando VMs aisladas, validando la seguridad del entorno	Aplicar
OG3	Evaluar el impacto de la economía underground sobre la seguridad organizacional, justificando recomendaciones de defensa	Evaluar
OG4	Diseñar estrategias de detección basadas en técnicas de living-off-the-land, demostrando eficacia	Crear

4.3.2 Específicos por Unidad

Unidad	Código	Resultado	Nivel Bloom
U1	OE1.1	Listar las diferencias entre web clara, deep web y dark web	Recordar
U1	OE1.2	Explicar el funcionamiento de la red Tor	Comprender
U2	OE2.1	Configurar un entorno Whonix para acceso seguro	Aplicar
U3	OE3.1	Analizar un proof of concept de Log4Shell	Analizar
U4	OE4.1	Identificar técnicas de evasión en loaders	Recordar

Unidad	Código	Resultado	Nivel Bloom
U5	OE5.1	Examinar el código de un information stealer	Analizar
U6	OE6.1	Comparar banking trojans Android vs Windows	Analizar
U7	OE7.1	Desempacar malware usando técnicas estáticas	Aplicar
U8	OE8.1	Interpretar tráfico C2 de Cobalt Strike	Comprender
U9	OE9.1	Diagnosticar uso de LOLBins en un incidente	Analizar
U10	OE10.1	Evaluar la seguridad de un locker de ransomware	Evaluar
U11	OE11.1	Comparar técnicas de ransomware Linux vs Windows	Analizar
U12	OE12.1	Proponer mitigaciones para futuras amenazas	Crear

4.4 4. Metodología

El curso sigue el enfoque ABACOM de **aprendizaje activo** con: - **60% práctica:** Laboratorios con ejecución manual de comandos - **30% teoría:** Conceptos, casos de estudio y análisis - **10% autónomo:** Lecturas, ejercicios y proyectos

Los laboratorios usan VMs completamente aisladas. **No se permite el copy-paste** — cada comando se escribe manualmente para construir competencia real.

4.5 5. Evaluación

4.5.1 Matriz de Evaluación

Resultado	Pond.	Instrumento	Tipo	Criterios	Semana
OE1.1- OE1.2	5%	Lab 1: Introducción a Tor	Forma- tiva	VM funcionando, acceso exitoso 70%	2
OE2.1	10%	Quiz 2: OPSEC y Whonix	Suma- tiva	70% correctas	2
OE3.1	15%	Lab 3: Análisis de exploits	Forma- tiva	Identifi- cación correcta de vulnerabili- dades 70%	4
OE4.1	5%	Quiz 4: Loaders	Forma- tiva	70% correctas	5
OE5.1	5%	Lab 5: Stealers	Forma- tiva	Extracción correcta de IOCs 70%	6
OE6.1	5%	Quiz 6: Banking trojans	Forma- tiva	70% correctas	7
OE7.1	10%	Lab 7: Unpacking	Forma- tiva	Payload recuperado exitosamente 70%	8
OE8.1	10%	Quiz 8: C2 Frameworks	Suma- tiva	70% correctas	9
OE9.1	5%	Lab 9: LOLBins	Forma- tiva	Técnicas detectadas correcta- mente 70%	10
OE10.1	10%	Quiz 10: Ransomware	Suma- tiva	70% correctas	11
OE11.1	5%	Lab 11: Linux ransomware	Forma- tiva	Análisis completado	12
OG1-OG4	20%	Proyecto Final	Suma- tiva	Rúbrica adjunta	13-15

4.6 6. Bibliografía

4.6.1 Básica

1. Kaye, L. (2026). *Dissecting the Dark Web*. No Starch Press. ISBN: 978-1-7185-0461-5.
2. Saello, J. (2023). *Practical Malware Analysis*. No Starch Press.

3. Kolias, V. et al. (2022). *Cybersecurity Education: A Hands-On Approach*. Springer.

4.6.2 Complementaria

1. MITRE ATT&CK Framework — <https://attack.mitre.org>
2. NIST SP 800-83 - Guide to Malware Incident Prevention and Handling
3. GitHub: DissectingTheDarkWeb - <https://github.com/DissectingTheDarkWebBook>

Part I

Unidad 1: Fundamentos de la Dark Web

Chapter 5

Fundamentos de la Dark Web

Chapter 6

Unidad 1: Fundamentos de la Dark Web

6.1 1. Introducción

¿Alguna vez te has preguntado cómo es posible que millones de datos robados se comercien en la dark web? ¿Cómo los cibercriminales acceden a estos mercados ocultos sin ser detectados? En 2021, el ataque a Colonial Pipeline puso en evidencia la existencia de este ecosistema criminal. Pero la dark web no es simplemente un “lugar oscuro” de internet; es una red compleja con sus propias reglas, herramientas y economía.

Esta unidad te da la base para entender **qué es la dark web, cómo se diferencia de internet que conocemos, y por qué es importante para la ciberseguridad.**

6.1.1 Conexión al contexto

La dark web representa el **3% restante** del total de información en internet. Mientras que internet visible (surface web) es accesible mediante motores de búsqueda, la dark web requiere herramientas especializadas y está compuesta principalmente por servicios criminales.

6.2 2. Contenido Teórico

6.2.1 2.1. La Web, el Deep Web y la Dark Web

Los motores de búsqueda usan **crawlers** que indexan páginas. El archivo `robots.txt` indica qué contenido indexar. La **deep web** es el 95%+ de internet

no indexado (passwords, bases de datos, paywalls). La **dark web** es el 3% restante: sitios **.onion** accesibles solo vía Tor.

6.2.2 2.2. Onion Routing Detallado

El proceso usa **3 nodos** con capas de encriptación:

💡 Tres nodos de Tor

Nodo	Conoce	No conoce
Entry Guard	IP origen	Destino final
Relay Node	Nodo anterior/siguiente	IP origen o destino
Exit Node	Destino final	IP origen

Comandos de instalación Tor Browser (Linux):

```
tar -xvf tor_browser_archive.tar.xz
./start-tor-browser.desktop
```

6.2.3 2.3. OPSEC esencial

- Usar Whonix-Gateway + Whonix-Workstation
- VPN encima de Tor para ocultar uso de Tor
- VM dedicada, nada de cuentas personales
- Wipe/reimage fácil del sistema

6.2.4 2.4. deepdarkCTI

Fuente para encontrar direcciones **.onion**: repositorio de inteligencia abierta.

6.3 3. Aplicaciones Prácticas

6.3.1 Escenario 1: Verificación de anonimato

```
# En Whonix
curl --socks5 127.0.0.1:9050 https://check.torproject.org/api/ip
# Output: {"IsExit": true, "IP": "[IP EXCLUSIVA TOR]"}

```

6.3.2 Escenario 2: Búsqueda de fuentes

deepdarkCTI provee URLs **.onion** verificables para investigación.

6.4 3. Aplicaciones Prácticas

6.4.1 Escenario 1: Navegando foros ocultos

Un investigador encuentra un foro .onion que vende credenciales robadas. ¿Cómo acceder sin exponer su identidad?

Requisitos: Whonix (gateway + workstation), encuesta de amenazas, mecanismo de verificación.

6.4.2 Escenario 2: Investigando precios de exploits

Un analista ve varios exploits vendidos por \$5,000 cada uno. ¿Qué indica esto sobre el mercado?

Análisis: Los precios revelan la demanda, la complejidad y el valor percibido.

6.5 4. Caso de Estudio: El modelo Cyber Kill Chain

El libro utiliza el modelo **Cyber Kill Chain** de Lockheed Martin para estructurar el ataque:

Fase	Descripción	Herramientas en dark web
1. Reconocimiento	Identificar objetivos	Herramientas de escaneo
2. Arma	Crear vector de ataque	Exploits, phishing kits
3. Entrega	Llevar arma al objetivo	Packers, loaders
4. Explotación	Ejecutar código malicioso	Exploit builders
5. Instalación	Persistir en el sistema	Backdoors, RATs
6. Comando y Control	Comunicación con víctima	C2 frameworks
7. Acción en Objetivo	Robo de datos, ransomware	Toolkits de exfiltración

6.6 5. Errores Comunes

6.6.1 Misconception: “Tor hace todo el trabajo de anonimato”

Por qué es incorrecto: Tor solo protege el tráfico de red. Si envías tu nombre real, cookies de sesión previas, o usas el mismo lenguaje de escritura, puedes ser identificado.

Comprensión correcta: Tor es una herramienta que debes combinar con buenas prácticas de OPSEC: VM aislada, nada de personal identificable, comportamiento neutro.

6.6.2 Misconception: “La dark web es solo para criminales”

Por qué es incorrecto: Periodistas, activistas, y personas bajo regímenes opresivos usan la dark web para comunicación segura.

Comprensión correcta: La dark web es una herramienta de anonimato. Su uso depende de las intenciones del usuario.

6.7 6. Actividades

6.7.1 Lecturas Asignadas

Obligatoria: Kaye, L. (2026). *Dissecting the Dark Web*, Capítulos 1-2, pp. 1-50.

Opcional: “How Tor Works” — [Electronic Frontier Foundation](#)

6.7.2 Ejercicios Prácticos

6.7.2.1 Ejercicio 1: Identificar tipos de web

Objetivo: Diferenciar entre surface, deep y dark web.

Pasos: 1. Lista 5 ejemplos de surface web (ej: wikipedia.org) 2. Lista 5 ejemplos de deep web (ej: gmail.com) 3. Explica por qué cada uno pertenece a su categoría

Verifica: Las diferencias clave están claramente identificadas.

6.7.2.2 Ejercicio 2: Simular onion routing

Objetivo: Entender el concepto de enrutamiento en capas.

Pasos: 1. Escribe un mensaje de ejemplo 2. Encripta “manualmente” usando 3 claves diferentes (simulado) 3. Dibuena el flujo de cómo cada nodo lo recibe y lo pasa

Verifica: El diagrama muestra claramente las capas y los nodos.

6.7.3 Preguntas de Discusión

1. ¿Deben los gobiernos prohibir tecnologías como Tor? ¿Por qué o por qué no?
2. ¿Cómo afecta el anonimato en la dark web al modelo de responsabilidad en ciberseguridad?

6.7.4 Auto-Evaluación

6.7.5 Preguntas de Verificación

1. **MCQ:** ¿Cuál capa del modelo OSI maneja la encriptación para Tor?
 - a) Física
 - b) Enlace
 - c) Red
 - d) Transporte

Respuesta: d) Transporte. Las conexiones TLS protegen la capa de transporte.

2. **Verdadero/Falso:** La dark web representa más del 50% del contenido de internet.

Falso. La dark web es menos del 3% del total.

3. **Corto:** ¿Qué significa “onion routing” en una frase?

Respuesta: Enrutamiento en capas donde cada nodo solo conoce su segmento de la ruta.

6.8 7. Bibliografía

6.8.1 Principal

- Kaye, L. (2026). *Dissecting the Dark Web*. No Starch Press. ISBN: 978-1-7185-0461-5.

6.8.2 Papeles

- Anderson, R. (2021). “The Tor Network: A Survey”. *Journal of Cybersecurity*, 7(2). DOI: 10.1093/cybsec/tyab008

6.8.3 Estándares

- RFC 4949 — Internet Security Glossary

6.8.4 Digital

- [Tor Project Documentation](#)
- [MITRE ATT&CK - Initial Access](#)

6.9 8. Tareas Anti-IA

6.9.1 Tarea 1: Dibujo manual

Tarea: En papel, dibuja el flujo de onion routing con 3 nodos. Incluye: - Dirección IP de origen - Capas de encriptación - Qué ve cada nodo

Regla: Sin herramientas digitales. Toma foto y sube. Calificación: completitud, etiquetas, precisión.

6.9.2 Tarea 2: Explicación oral

Tarea: Graba un video de 3 minutos explicando la diferencia entre deep web y dark web como si enseñaras a un compañero.

Requerimientos: Usa analogías, responde 1 pregunta adicional del instructor.

Evaluación: Claridad, corrección, capacidad de responder preguntas.

Chapter 7

Laboratorio 1: Introducción a Tor y Whonix

Chapter 8

Laboratorio 1: Introducción a Tor y Whonix

ADVERTENCIA DE SEGURIDAD

Este laboratorio debe ejecutarse SOLO en: - Máquina virtual aislada (Whonix, VirtualBox/VMware) - Red virtualhost-only - Sin acceso a redes internas de la institución

No ejecutar en máquina host. Cualquier descarga o interacción es bajo tu responsabilidad.

8.1 Objetivo

Configurar y verificar un entorno Whonix seguro para exploración de la dark web, entendiendo cada componente del sistema.

8.2 Requisitos previos

- VirtualBox o VMware instalado
- 8GB RAM mínimo disponible
- Conexión a internet estable

8.3 Paso 1: Descargar Whonix

8.3.1 1.1. Identificar fuentes oficiales

Objetivo: Encontrar la página oficial de Whonix.

Pasos manuales: 1. Abre una terminal en tu máquina host 2. Ejecuta: `nslookup whonix.org` (NO copiar-pegar) 3. Verifica que la IP resuelta coincida con documentación oficial

Output esperado:

```
Server:      8.8.8.8
Address:     8.8.8.8#53
```

Non-authoritative answer:

```
Name:   whonix.org
Address: [IP REAL]
```

8.3.2 1.1. DeepdarkCTI para URLs .onion

Objetivo: Identificar fuentes legítimas de URLs de dark web.

Pasos manuales: 1. Busca “deepdarkCTI github” en Google (desde VM limpia) 2. Identifica el repositorio oficial 3. Lista URLs .onion verificables en el README

8.3.3 1.2. Verificar firma GPG

Objetivo: Confirmar autenticidad de la ISO de Whonix.

Pasos manuales: 1. Descarga el archivo .asc de firma 2. Importa la clave: `gpg --recv-keys [clave oficial]` 3. Verifica: `gpg --verify [archivo.asc]`

Output esperado:

```
gpg: Good signature from "Whonix Release Signing Key"
```

8.4 Paso 2: Configurar Whonix Gateway

8.4.1 2.1. Crear red host-only

Objetivo: Aislar la VM de redes externas.

Pasos manuales:

```
# En host (macOS/Linux)
VBoxManage hostonlyif ipconfig vboxnet0 --ip 192.168.56.1
```

8.4.2 2.2. Configurar interfaz

En VirtualBox: 1. Configura **Whonix-Gateway** con Adaptador 1: NAT 2. Configura **Whonix-Workstation** con Adaptador 1: Host-only

8.5 Paso 3: Verificar funcionamiento de Tor

8.5.1 3.1. Chequear servicio Tor

Objetivo: Confirmar que Tor está corriendo.

Pasos manuales:

```
# En Whonix Gateway
sudo systemctl status tor@default
```

Output esperado:

```
tor@default.service - Anonymizing overlay network
Loaded: loaded
Active: active (running)
```

8.5.2 3.2. Verificar IP pública

Objetivo: Confirmar anonimato.

Pasos manuales:

```
# En Whonix Workstation
curl --socks5-hostname 127.0.0.1:9050 https://check.torproject.org/api/ip
```

Output esperado:

```
{"IsExit": true, "IP": "[IP DE SALIDA TOR]"}
```

8.6 Paso 4: Navegador Tor Browser

8.6.1 4.1. Configuración segura

Verifica en Tor Browser: 1. Security Settings → **Safest** (máximo) 2. No instalar plugins 3. No guardar contraseñas 4. No descargar archivos ejecutables

8.6.2 4.2. Acceso a servicio de prueba

Objetivo: Verificar navegación segura.

Pasos manuales: 1. Navega a <http://check.torproject.org> 2. Verifica mensaje “Congratulations. This browser is configured to use Tor.” 3. Toma captura de pantalla (solo la página de verificación)

8.7 Verificación Final

Checkpoint	Comando	Resultado esperado
1	<code>systemctl status tor@default</code>	active (running)
2	<code>curl --socks5 127.0.0.1:9050 https://ipinfo.io/ip</code>	IP diferente a tu real
3	Tor Browser → <code>check.torproject.org</code>	Mensaje de confirmación

8.8 Rubrica de laboratorio

Criterio	Excelente (5)	Bueno (3)	Necesita Mejora (1)
Seguridad OPSEC	Todos los pasos seguros	1-2 riesgos menores	Multiple fallos de OPSEC
Ejecución manual	Todo ejecutado manualmente	Algunos copy-paste	Mucha automatización
Documentación	Screenshots + notas claras	Screenshots básicos	Incompleto
Verificación	Todas las IPs verificadas	Algunas verificadas	No verificado

Chapter 9

Quiz 1: Fundamentos de la Dark Web

Chapter 10

Quiz 1: Fundamentos de la Dark Web

10.1 Instrucciones

Responde las siguientes preguntas. Muestra tu trabajo donde sea necesario. Usa tus propias palabras.

10.2 Preguntas

10.2.1 1. Desarrollo (Bloom: Comprender)

Explica en 3-5 oraciones la diferencia técnica entre el Surface Web y la Dark Web. Incluye: - Cómo se indexa cada uno - Qué software se requiere para acceder

Puntos: 10

10.2.2 2. Opción múltiple (Bloom: Recordar)

¿Cuántos nodos intermedios procesa el tráfico en la red Tor por defecto?

- a) 1 nodo (entrada única)
- b) 3 nodos (entrada, medio, salida)
- c) 5 nodos (configuración máxima)
- d) El número varía según carga

Respuesta:

10.2.3 3. Verdadero/Falso (Bloom: Evaluar)

La deep web contiene exclusivamente contenido ilegal y está oculta por malas intenciones.

Respuesta:

Justificación:

10.2.4 4. Análisis (Bloom: Analizar)

Dado el siguiente output de `curl` usando un proxy Tor:

```
{"IsExit": false, "IP": "185.220.101.1"}
```

¿Qué puedes inferir? - ¿Estás usando Tor? - ¿Cuál es el IP de salida? - ¿Qué indica “IsExit: false”?

Puntos: 10

10.2.5 5. Comando (Bloom: Aplicar)

Escribe el comando para verificar tu IP usando el proxy SOCKS de Tor. No copies el ejemplo del laboratorio — escribe desde cero.

Respuesta:

10.2.6 6. Diseño (Bloom: Crear)

Dibujena (en papel) el flujo de información desde tu navegador hasta un servidor .onion. Etiqueta: - Cliente - Entry guard - Relay nodes - Exit node (si aplica) - Servidor destino

Puntos: 10

10.3 Rubrica rápida

Pregunta	Puntos
1	10
2	5

Pregunta	Puntos
3	5
4	10
5	5
6	10
Total	45

Passing score: 32/45 (71%)

Part II

Unidad 2: Acceso Seguro y OPSEC

Chapter 11

Acceso Seguro y OPSEC

Chapter 12

Unidad 2: Acceso Seguro y OPSEC

12.1 1. Introducción

Acceder a la dark web sin el anonimato adecuado es como entrar a una guerra sin equipo de protección. Las amenazas incluyen rastreo de IP, malware, y hasta intervención legal. Esta unidad te enseña a protegerte.

12.2 2. Contenido Teórico

12.2.1 2.1. Principios de OPSEC

Operational Security (OPSEC) es la disciplina de proteger información sensible. Los principios clave:

1. **Separación:** Ni tus datos personales ni tu comportamiento normal en la dark web
2. **Comportamiento neutral:** Escribe de forma diferente, actúa de forma diferente
3. **Infraestructura dedicada:** VMs limpias, no tu máquina principal

 Preguntas que nunca debes responder en dark web

- “¿Dónde vives?”
- “¿Cuál es tu trabajo real?”
- “¿Qué lenguaje escribo normalmente?”
- “¿Qué hora es en mi zona horaria?”

12.2.2 2.2. Arquitectura Whonix

Whonix tiene **dos VMs**:

Componente	Función	Protección
Gateway	Enrutamiento Tor	Aísla tráfico
Workstation	Navegador y herramientas	Sin IP directa

[Internet] → [Gateway Whonix] → [Workstation Whonix] → [Usuario]

12.2.3 2.3. Herramientas de defensa

- **VM isolation**: VirtualBox con red host-only
- **Network fingerprinting protection**: User agent randomizado
- **Timing attacks**: No patrones predecibles
- **Correlation resistance**: No doble uso de sesión

12.3 3. Aplicaciones Prácticas

12.3.1 Escenario: Investigador identificado

Un investigador fue identificado porque: 1. Usó su frase típica en foros 2. Visitó sitios a la misma hora todos los días 3. Usó su navegador principal con Tor

12.3.2 Escenario: Setup seguro

Un analista correcto: 1. VM completamente nueva 2. Comportamiento impredecible 3. No personaliza nada

12.4 4. Errores Comunes

12.4.1 Misconception: “Whonix es suficiente solito”

¿Por qué es falso?: Whonix protege red, pero si usas mismo idioma, horarios, o patrones, la correlación es posible.

12.4.2 Misconception: “Puedo usar mi máquina para esto”

¿Por qué es falso?: Cualquier instalación previa, cookies, o configuraciones son huellas.

12.5 5. Actividades

12.5.1 Lectura

- Kaye, L. (2026). *Dissecting the Dark Web*, Sección 1.2-1.5.

12.5.2 Ejercicios

12.5.2.1 Ejercicio 1: Matriz de riesgos

Lista 5 riesgos al acceder a dark web y propone mitigación.

12.5.2.2 Ejercicio 2: Simulación de timeline

Crea un horario impredecible para actividades de investigación.

12.6 6. Auto-Evaluación

1. **Definir:** ¿Qué significa operational security?
2. **Explicar:** ¿Por qué dos VMs en Whonix?
3. **Identificar:** Nombra 3 errores de OPSEC comunes.

12.7 7. Bibliografía

- Kaye, L. (2026). *Dissecting the Dark Web*, Capítulo 1.
- NSA. (2020). *OPSEC Guidelines*. DoD 5200.28.

Chapter 13

Laboratorio 2: Configuración Whonix Avanzada

Chapter 14

Laboratorio 2: Configuración Whonix Avanzada

14.1 Objetivo

Configurar Whonix con reglas de firewall adicionales y verificar la protección contra correlation attacks.

14.2 Paso 1: Configurar firewall host

14.2.1 1.1. Reglas iptables

```
# En host (macOS/Linux)
sudo iptables -A OUTPUT -o lo -j ACCEPT
sudo iptables -A OUTPUT -m conntrack --ctstate ESTABLISHED -j ACCEPT
sudo iptables -A OUTPUT -j DROP
```

14.3 Paso 2: Configurar Whonix Gateway

14.3.1 2.1. Editar configuración Tor

```
# En Whonix Gateway
sudo nano /etc/tor/torrc
# Agregar:
```

```
# DisableNetworkTime=true
# NewCircuitPeriod=600
```

14.4 Paso 3: Verificar aislamiento

14.4.1 3.1. Test de DNS leak

```
# En Workstation
nslookup google.com
# Debe fallar o resolver vía Tor
```

14.5 Verificación

Checkpoint	Método	Resultado
Firewall	iptables -L	Reglas aplicadas
DNS leak	nslookup	Sin leak
IP pública	Tor check	IP diferente

14.6 Rubrica

Criterio	5 pts	3 pts	1 pt
Configuración	Todo correcto	2 errores menores	Errores críticos
Verificación	4/4 checkpoints	2-3 checkpoints	<2 checkpoints
Documentación	Completa	Básica	Incompleta

Chapter 15

Quiz 2: OPSEC y Whonix

Chapter 16

Quiz 2: OPSEC y Whonix

16.1 Preguntas

16.1.1 1. Desarrollo

¿Por qué es crítico usar una VM completamente nueva para navegar dark web?

16.1.2 2. Opción múltiple

¿Cuántas VMs tiene Whonix por defecto?

- a) 1
- b) 2
- c) 3
- d) Depende de la instalación

16.1.3 3. Verdadero/Falso

Los horarios predecibles de navegación pueden ser una señal de identificación.

16.1.4 4. Análisis

Dado este log de firewall:

```
DROP tcp -- anywhere 192.168.1.100  
ACCEPT tcp -- anywhere 10.152.152.10
```

¿Qué política de red se está aplicando?

16.1.5 5. Comando

Escribe el comando para verificar el estado del servicio Tor.

Puntuación total: 30 pts | **Passing:** 21 pts (70%)

Part III

Unidad 3: Vulnerabilidades y Exploits

Chapter 17

Vulnerabilidades, Exploits y Acceso Inicial

Chapter 18

Unidad 3: Vulnerabilidades, Exploits y Acceso Inicial

18.1 1. Introducción

La dark web funciona como un mercado donde el producto más valioso es el **acceso**. Los Initial Access Brokers (IABs) venden puertas de entrada a organizaciones, mientras que exploits como Log4Shell se comercializan en paquetes listos para usar. Esta unidad te enseña a entender estos productos desde una perspectiva defensiva.

18.2 2. Contenido Teórico

18.2.1 2.1. Initial Access Brokers (IABs)

Los IABs venden **acceso verificado** con precios basados en: - Tamaño de la organización - Tipo de acceso (VPN, RDP, dominio) - Información MFA incluida

Tipo de acceso	Precio típico	Precio con MFA
Personal	\$10-\$100	\$50-\$200
Corporativo pequeño	\$100-\$500	\$300-\$800
Credenciales dominio	\$500-\$2000	\$1000-\$5000
AWS/GCP/Azure	\$1000-\$5000	\$2000-\$10000

18.2.2 2.2. Checkers vs Brute-Forcers

Herramienta	Función	Ejemplo del libro
Checkers	Verifica credenciales existentes	TMChecker
Brute-Forcers	Fuerza bruta para nuevas	Forti VPN Bruter

Los checkers automatizan la verificación: - 15 millón de credenciales sin verificar
= \$400-\$700 - 7,000 credenciales verificadas (corporativas + MFA) = \$1000+

18.2.3 2.3. Exploit Builders

No crean exploits nuevos — son **mecanismos de entrega**: - HTML-based phishing - LNK/URL attachments - Malvertising integrado

Nota del libro: Más baratos que exploits reales, requieren menos skills técnicos.

18.3 3. Caso de Estudio: TMChecker

TMChecker verifica credenciales corporativas:

1. **Entrada:** Lista de correos/usuarios
2. **Proceso:** Login automatizado a OWA/Office365
3. **Salida:** Archivo con credenciales válidas

18.3.1 Análisis técnico

```
# Pseudocódigo del proceso de verificación
def verify_credentials(username, password):
    session = requests.Session()
    response = session.post(
        "https://outlook.office365.com/owa/",
        data={"username": username, "password": password}
    )
    if "authenticated" in response.text:
        return True
    return False
```

18.3.2 Señales de detección

- Múltiples logins fallidos seguidos
- User-Agent idéntico en todas las peticiones
- Horarios predecibles de ataque

18.4 4. Errores Comunes

18.4.1 Misconception: “Los exploits son imposibles de usar”

¿Por qué es falso?: Los IABs empaquetan exploits con instrucciones paso a paso. Baja la barrera de entrada.

18.4.2 Misconception: “Phishing es ineficaz”

¿Por qué es falso?: El 30% de los ataques exitosos comienzan con phishing. Es rentable.

18.5 5. Actividades

18.5.1 Lectura

- Kaye, L. (2026). *Dissecting the Dark Web*, Capítulo 2.

18.5.2 Ejercicios

18.5.2.1 Ejercicio 1: Análisis de CVE

Selecciona Log4Shell y explica: - Vector de ataque - Condiciones necesarias - Mitigación

18.5.2.2 Ejercicio 2: Identificar IoCs

Dado un log de autenticación, identifica 3 indicadores de TMChecker.

18.6 6. Auto-Evaluación

1. **Listar:** 5 tipos de acceso vendidos por IABs
2. **Explicar:** Cómo verifica un checker las credenciales
3. **Analizar:** Diferencias entre Zphisher y Greatness kit

18.7 7. Bibliografía

- MITRE ATT&CK — Initial Access Tactics
- Kaye, L. (2026). *Dissecting the Dark Web*, Capítulo 2.
- NIST NVD — CVE database.

Chapter 19

Laboratorio 3: Análisis de Credenciales y Checkers

Chapter 20

Laboratorio 3: Análisis de Credenciales y Checkers

20.1 Objetivo

Analizar el proceso de TMChecker para verificación de credenciales corporativas.

20.2 Paso 1: Identificar servicios objetivo

20.2.1 1.1. Servicios corporativos comunes

Servicio	Puerto	Protocolo
OWA/Office365	443	HTTPS
VPN SSL	443	HTTPS
RDP	3389	TCP
SSH	22	TCP

20.3 Paso 2: Identificar señales de TMChecker

20.3.1 2.1. User-Agent estándar

```
# TMChecker usa User-Agent predecible  
curl -H "User-Agent: TMChecker/1.0" target.com/login
```

20.3.2 2.2. Patrones de login

```
# Secuencial: user1, user2, user3...  
# 0 usando lista predefinida  
# Siempre mismo User-Agent  
# Siempre mismo timing entre requests
```

20.4 Paso 3: Identificar en logs

20.4.1 3.1. Buscar patrones

```
# IPs múltiples, mismo User-Agent  
awk -F'"' '/Login/{print $6}' access.log | sort | uniq -c
```

20.5 Verificación

Checkpoint	Resultado
User-Agent	Identificado
Timing	Analizado
IP patterns	Detectado

Chapter 21

Quiz 3: Vulnerabilidades, Exploits y Credenciales

Chapter 22

Quiz 3: Vulnerabilidades, Exploits y Credenciales

22.1 Preguntas

22.1.1 1. Desarrollo

Explica la diferencia entre un **checker** y un **brute-forcer** con un ejemplo de cada uno.

22.1.2 2. Opción múltiple

¿Cuál es el precio típico de credenciales corporativas VERIFICADAS (con MFA) según el libro?

- a) \$100-\$500
- b) \$500-\$1500
- c) \$1000-\$5000
- d) \$1500-\$3000

22.1.3 3. Verdadero/Falso

Los exploit builders crean vulnerabilidades nuevas desde cero.

22.1.4 4. Análisis

Si ves credenciales de 7,000 corporativas a \$1500+ y 15 millones de no verificadas a \$700, ¿qué indica el precio diferencial?

22.1.5 5. Comando

Escribe el command para identificar User-Agent repetido en logs.

22.1.6 6. Diseño

¿Qué diferencia hay entre un exploit real y un exploit builder? (máx 3 líneas)

Part IV

Unidad 4: Técnicas de Entrega de Malware

Chapter 23

Técnicas de Entrega de Malware

Chapter 24

Unidad 4: Técnicas de Entrega de Malware

24.1 1. Introducción

Después de obtener acceso, el atacante necesita **entregar** el payload. Los loaders son el primer estadio de ejecución; los botnets proporcionan infraestructura masiva. Esta unidad analiza técnicas reales de entrega.

24.2 2. Loaders

24.2.1 2.1. Qué es un loader

Un loader **asegura la entrega** del payload. Pueden incluir: - Keylogging - Screenshots - Ejecución de comandos - Funciones de discovery

24.2.2 2.2. SmokeLoader (desde 2013)

Técnicas de evasión identificadas: - **Opaque predicates**: Expresiones que siempre son true/false pero difíciles de determinar - **Function/string obfuscation**: Encripta funciones y strings para ocultar propósito - **Anti-hooking**: Detecta y evita hooking de sandboxes - **Anti-debugging**: Chequea flags de debugging (BeingDebugged) - **Hash-based import resolution**: Oculta funciones importadas usando hashes

Precio en dark web: ~\$2,500 por builder que genera HTA files

24.2.3 2.3. BunnyLoader

Características: - **File download y execution** - **Anti-analysis techniques** (sleep, delays) - **Modular** con plugins - **Registry persistence**

24.3 3. Botnets

24.3.1 3.1. Mirai Family

Mirai (2016) revolucionó el DDoS: - **Scanning**: Telnet en puertos 23/2323 - **Brute force**: Credenciales por defecto - **Infection**: Binario MIPS/ARM

24.3.2 3.2. CosaNostra Botnet

Botnet moderna con: - **C2 via Tor** - **DDoS** + **crypto mining** - **Auto-update**

24.4 4. Ejercicios

1. Analiza un loader estático con strings y entropy
2. Identifica señales de Mirai en logs de red

24.5 5. Auto-Evaluación

1. ¿Qué hace un loader?
2. Métodos anti-debug de SmokeLoader
3. Protocolo de infección de Mirai

Chapter 25

Laboratorio 4: Análisis de Loaders

Chapter 26

Laboratorio 4: Análisis de Loaders

26.1 Objetivo

Identificar técnicas de evasión en SmokeLoader y BunnyLoader usando análisis estático.

26.2 Paso 1: SmokeLoader Anti-debug

26.2.1 1.1. Chequeo de debugger

```
; Assembly típico  
call IsDebuggerPresent  
test al, al  
jz skip_evasion
```

26.3 Paso 2: BunnyLoader String Obfuscation

26.3.1 2.1. Identificar strings encriptadas

```
# Entropy analysis  
pecheck.py malware.exe | grep -A5 -B5 "entropy"
```

26.4 Paso 3: Identificar rutas de descarga

26.4.1 3.1. URLs ocultas

```
strings malware.exe | grep -E "https?://"
```

26.5 Verificación

Checkpoint	Resultado
Anti-debug	Identificado
String enc	Rutas encontradas
URLs	Lista de C2

Chapter 27

Quiz 4: Malware Delivery Techniques

Chapter 28

Quiz 4: Malware Delivery Techniques

28.0.1 1. Desarrollo

¿Qué diferencia a un loader de un botnet?

28.0.2 2. Opción múltiple

¿Qué técnica usa SmokeLoader para detectar depuración?

- a) Chequeo de IP pública
- b) IsDebuggerPresent API
- c) Análisis de tráfico
- d) Fingerprint de navegador

28.0.3 3. Verdadero/Falso

Mirai se propaga mediante fuerza bruta de credenciales Telnet.

28.0.4 4. Análisis

¿Qué indica alta entropía en un binario?

28.0.5 5. Comando

Escribe el comando para identificar strings ofuscadas.

Part V

Unidad 5: Information Stealers

Chapter 29

Information Stealers

Chapter 30

Unidad 5: Information Stealers

30.1 1. Introducción

Los stealers son el **columna vertebral** de la economía del underground. Roban credenciales, cookies, wallets, y datos sensibles. Este mercado genera miles de millones anuales.

30.2 2. Proceso de un stealer

1. Harvesting → 2. Collection → 3. Exfiltration → 4. Monetización

30.2.1 2.1. Victim Download

- Archivos ZIP
- Documentos maliciosos
- Cracks de software

30.2.2 2.2. Data Collection

Tipo de dato	Ubicación típica
Passwords navegadores	AppData/Local/*/Login Data
Cookies	Cookies.sqlite, network.cookie
Cryptowallets	AppData/Roaming/*/wallet.dat
Credit cards	Navegadores, keylogger

30.2.3 2.3. Exfiltration

- **C2 domains:** .ru, .tk
- **Telegram bots:** Envío directo
- **FTP:** Servidores comprometidos

30.3 3. Caso: Raccoon Stealer

30.3.1 Funcionalidad clave

```
# Pseudocódigo Raccoon
def collect_browser_data():
    browsers = ["Chrome", "Firefox", "Edge"]
    for browser in browsers:
        # Extraer logins
        logins = extract_logins(browser)
        # Extraer cookies
        cookies = extract_cookies(browser)
        # Extraer history
        history = extract_history(browser)
```

30.3.2 Evasion

- **Mutex:** Evita doble ejecución
- **VM detection:** Salta en máquinas virtuales
- **Sleep:** Delay para evitar sandbox

30.4 4. Ejercicios

1. Analizar strings de SapphireStealer
2. Identificar rutas de extracción de credenciales

30.5 5. Auto-Evaluación

1. ¿Por qué siguen funcionando los stealers?
2. Métodos de exfiltración más comunes
3. Diferencias Raccoon vs RedLine

Chapter 31

Laboratorio 5: Análisis de Information Stealers

Chapter 32

Laboratorio 5: Análisis de Information Stealers

32.1 Objetivo

Identificar rutas de extracción de credenciales en SapphireStealer usando técnicas estáticas.

32.2 Paso 1: Identificar rutas de datos

32.2.1 1.1. Rutas de navegadores

```
strings SapphireStealer.exe | grep -i -E "(appdata|chrome|firefox|edge|login)"
```

32.3 Paso 2: Identificar rutas de cryptowallets

32.3.1 2.1. Wallets comunes

```
strings SapphireStealer.exe | grep -i -E "(wallet|bitcoin|ethereum|crypto)"
```

32.4 Paso 3: Identificar rutas de exfiltración

32.4.1 3.1. URLs de C2

```
strings SapphireStealer.exe | grep -i -E "(http|https|ftp|dns|telegram)"
```

32.5 Verificación

Checkpoint	Resultado esperado
Browser paths	Wallets identificados
Wallet paths	Rutas extraídas
C2 URLs	Dominios encontrados

Chapter 33

Quiz 5: Information Stealers

Chapter 34

Quiz 5: Information Stealers

34.0.1 1. Listar

5 tipos de datos que roban los stealers.

34.0.2 2. Explicar

¿Por qué siguen siendo efectivos los stealers?

34.0.3 3. Analizar

¿Qué diferencia hay entre Raccoon y RedLine stealers?

34.0.4 4. Identificar

Ruta típica de credenciales en Chrome.

34.0.5 5. Comando

Escribe el comando para buscar strings relacionadas a cryptowallets.

Part VI

Unidad 6: Banking Trojans

Chapter 35

Banking Trojans

Chapter 36

Unidad 6: Banking Trojans

36.1 1. Introducción

Los banking trojans son **malware financiero** especializado en robo de credenciales bancarias. Android usa Accessibility API para overlay, Windows usa inyección de procesos.

36.2 2. Android Banking Trojans

36.2.1 2.1. Accessibility API Abuse

Los trojans solicitan permiso `android.permission.BIND_ACCESSIBILITY_SERVICE` para: - Leer pantalla - Interceptar clicks - Injectar overlays

36.2.2 2.2. Cerberus Overlay

```
// Pseudocódigo de overlay malicioso
public class OverlayService extends AccessibilityService {
    @Override
    public void onAccessibilityEvent(AccessibilityEvent event) {
        String packageName = event.getPackageName().toString();
        if (packageName.equals("com.bank.app")) {
            injectPhishingOverlay();
        }
    }
}
```

36.3 3. Windows Banking Trojans

36.3.1 3.1. TrickBot Browser Injection

Técnicas: - **Process injection** en navegadores - **Function hooking** API - **Web injects** para modificar páginas

36.3.2 3.2. Cadenas de ataque

1. Download → 2. Inject → 3. Hook → 4. Steal → 5. Exfiltrate

36.4 4. Mitigaciones

- Google Play Protect
- EDR con detección de overlays
- Políticas de no instalar APKs externos

36.5 5. Auto-Evaluación

1. ¿Qué hace AccessibilityService?
2. Técnica de inyección de TrickBot
3. Señales de detección de overlays

Chapter 37

Laboratorio 6: Banking Trojans Android

Chapter 38

Laboratorio 6: Banking Trojans Android

38.1 Objetivo

Analizar el uso de Accessibility API en trojans bancarios mediante inspección estática.

38.2 Paso 1: Identificar permisos

38.2.1 1.1. Manifest analysis

```
apktool d malware.apk
grep -A2 -B2 "android.permission.BIND_ACCESSIBILITY_SERVICE" malware/AndroidManifest.xml
```

38.3 Paso 2: Identificar overlays

38.3.1 2.1. Overlay code

```
grep -r "TYPE_APPLICATION_OVERLAY" malware/smali/
grep -r "WindowManager.LayoutParams" malware/smali/
```

38.4 Verificación

Checkpoint	Resultado
Accessibility perm	Identificado

Checkpoint	Resultado
Overlay code	Detectado
Suspicious perms	Listados

Chapter 39

Quiz 6: Banking Trojans

Chapter 40

Quiz 6: Banking Trojans

40.0.1 1. Identificar

Permiso de Android que abusa Cerberus para overlays.

40.0.2 2. Explicar

Técnica de process injection usada por TrickBot.

40.0.3 3. Comparar

Banking trojan vs RAT principal diferencia.

40.0.4 4. Verificar

Método para detectar overlays en Android.

40.0.5 5. Comando

APKtool command para decompilar un APK.

Part VII

Unidad 7: Packers y Crypters

Chapter 41

Packers y Crypters

Chapter 42

Unidad 7: Packers y Crypters

42.1 1. Introducción

Los packers **ofuscan** el malware para evadir AV/EDR. Los crypters en el underground son herramientas de venta que demuestran “funcionalidad”.

42.2 2. Técnicas de protección

42.2.1 2.1. String Obfuscation

```
// String ofuscada
char *enc = "\x48\x65\x6c\x6f"; // "Hello" XOR encrypted
for(int i=0; i<len; i++) dec[i] = enc[i] ^ 0xAA;
```

42.2.2 2.2. Control Flow Obfuscation

- Junk code insertion
- Opaque predicates
- Jump tables

42.2.3 2.3. Entropy Analysis

Entropy alta (> 7.0) indica: - Compresión - Encriptación
- Empaquetado

42.3 3. Proceso de Unpacking

42.3.1 3.1. Memory Allocation

1. VirtualAlloc con permisos PAGE_EXECUTE_READWRITE
2. Copia del stub desempacador
3. Desencryptado del payload

42.3.2 3.2. UpX Unpacking

```
# Identificar UpX
upx -l malware.exe

# Desempaquetar
upx -d malware.exe -o unpacked.exe
```

42.4 4. Ejercicios

1. Calcular entropy de archivo binario
2. Identificar UPX con strings y peid

42.5 5. Auto-Evaluación

1. Señales de archivo empaquetado
2. Método de unpacking manual
3. Uso de entropy en análisis

Chapter 43

Laboratorio 7: Unpacking de Malware

Chapter 44

Laboratorio 7: Unpacking de Malware

44.1 Objetivo

Desempaquetar un binario protegido usando técnicas estáticas y dinámicas.

44.2 Paso 1: Identificar packer

44.2.1 1.1. PEiD o Detect It Easy

```
diec malware.exe
# 0 buscar firmas comunes
strings malware.exe | head -20
```

44.3 Paso 2: Calcular entropy

44.3.1 2.1. Análisis de entropía

```
# Usar herramienta de entropía
entropyscan.py malware.exe
# Entropy alta (>7.0) indica compresión/criptación
```

44.4 Paso 3: Unpacking manual

44.4.1 3.1. Memory dump

En VMWare/VirtualBox: 1. Ejecutar en máquina aislada 2. Usar Process Dump: `procdump -ma malware.exe` 3. Analizar dump con IDA/Ghidra

44.5 Verificación

Checkpoint	Resultado
Packer ID	Identificado
Entropy	Valor calculado
Payload	Recuperado

Chapter 45

Quiz 7: Packers y Crypters

Chapter 46

Quiz 7: Packers y Crypters

46.0.1 1. Definir

¿Qué hace un packer en malware?

46.0.2 2. Identificar

Técnica para detectar malware empaquetado.

46.0.3 3. Explicar

Método de unpacking estático vs dinámico.

46.0.4 4. Diferenciar

Entropy alta significa qué en análisis.

46.0.5 5. Comando

Escribe el command para desempaquetar con UPX.

Part VIII

Unidad 8: Frameworks C2

Chapter 47

Frameworks Command-and-Control

Chapter 48

Unidad 8: Frameworks Command-and-Control

48.1 1. Introducción

Los frameworks C2 son **infraestructuras de control** para sistemas comprometidos. Cobalt Strike es el estándar de facto, pero el underground tiene variantes piratas.

48.2 2. Componentes de un C2

Componente	Función
Implant	Agente en víctima
Beacon	Comunicación periódica
Team Server	Control central
Staging	Configuración dinámica

48.3 3. Caso: Vermilion Strike vs Cobalt Strike

Vermilion Strike (copy de Cobalt Strike): - **Config decryption**: Algoritmo XOR simple - **Metadata collection**: Sistema, usuario, red - **Encrypted exfiltration**: AES-256

48.3.1 Técnicas de evasión

- **Sleep masks**: Cambian shellcode
- **Process hollowing**: Inyección en proceso legítimo

- **Named pipes:** Comunicación interna

48.4 4. Detección

48.4.1 4.1. Tráfico C2

Señales en red: - Conexiones HTTP recurrentes - User-Agent sospechosos - DNS tunneling

48.4.2 4.2. Sliver Detection

```
# Análisis de tráfico
sliver-server -s # Staging server logs

# Detección de beacon
netstat -ano | grep :443 # Conexiones sospechosas
```

48.5 5. Auto-Evaluación

1. Arquitectura de Cobalt Strike
2. Configuración de beacon
3. Métodos de detección de C2

Chapter 49

Laboratorio 8: Análisis de Frameworks C2

Chapter 50

Laboratorio 8: Análisis de Frameworks C2

50.1 Objetivo

Analizar configuración de Vermilion Strike/Cobalt Strike usando técnicas de extracción.

50.2 Paso 1: Identificar configuración

50.2.1 1.1. Strings sospechosas

```
strings malware.exe | grep -i -E "(beacon|teamserver|callback|jarm)"
```

50.3 Paso 2: Decodificar configuración

50.3.1 2.1. XOR decode

```
# Pseudocódigo para decode
def decode_config(data, key=0x55):
    return bytes([b ^ key for b in data])
```

50.4 Verificación

Checkpoint	Resultado
Config strings	Extraídas

Checkpoint	Resultado
Decryption	Completada
C2 domains	Identificadas

Chapter 51

Quiz 8: Frameworks C2

Chapter 52

Quiz 8: Frameworks C2

52.0.1 1. Identificar

Componentes principales de Cobalt Strike.

52.0.2 2. Explicar

Diferencia entre Beacon y Implant.

52.0.3 3. Analizar

Técnica de string deobfuscation en Vermilion Strike.

52.0.4 4. Verificar

Método para detectar tráfico C2 en red.

52.0.5 5. Comando

Escribe el comando para listar conexiones de red activas.

Part IX

Unidad 9: Living Off the Land

Chapter 53

Living Off the Land

Chapter 54

Unidad 9: Living Off the Land

54.1 1. Introducción

“Living Off the Land” significa usar **binarios legítimos** del sistema para actividades maliciosas. PowerShell, WMI, y herramientas de administrador se abusan para evadir detección.

54.2 2. LOLBins comunes

Binario	Técnica típica	MITRE TID
powershell.exe	Descarga y ejecución	T1059.001
wmic.exe	Enumeración de procesos	T1047
rundll32.exe	Ejecución de código	T1218.011
mshta.exe	HTML applications maliciosas	T1218.005
wscript.exe	Scripts JScript/VBScript	T1059.005

54.3 3. Técnicas por fase

54.3.1 3.1. Discovery

```
# Enumeración de dominio
Get-ADComputer -Filter *
arp -a
net view
```

54.3.2 3.2. Privilege Escalation

```
# Abuso de servicios débiles
sc query > services.txt
icacls C:\Windows\Temp /grant Everyone:F
```

54.3.3 3.3. Lateral Movement

```
# WMI para ejecución remota
wmic /node:192.168.1.10 process call create "malware.exe"
psexec \\192.168.1.10 -u admin -p passwd cmd.exe
```

54.4 4. Caso: Conti Playbook

Documentos filtrados muestran: - Uso de PsExec para movimiento lateral - BloodHound para mapeo de AD - Rubeus para kerberoasting

54.5 5. Mitigaciones

- **Constrained Language Mode** para PowerShell
- **AppLocker** para limitar binarios
- **EDR con detección de comportamiento**
- **Logging ampliado de procesos**

54.6 6. Auto-Evaluación

1. Lista 3 LOLBins y sus técnicas
2. Explica cómo funciona BloodHound
3. Propone mitigación para PsExec

Chapter 55

Laboratorio 9: Living Off the Land

Chapter 56

Laboratorio 9: Living Off the Land

56.1 Objetivo

Identificar uso de LOLBins en logs de sistema mediante análisis de eventos.

56.2 Paso 1: Analizar logs de proceso

56.2.1 1.1. Sysmon events

```
<!-- Evento 1: Process Create -->
<Event>
  <EventData>
    <Data Name="Image">powershell.exe</Data>
    <Data Name="CommandLine">-enc [payload]</Data>
  </EventData>
</Event>
```

56.3 Paso 2: Identificar patrones sospechosos

56.3.1 2.1. PowerShell encoded

```
# Buscar encoded commands
grep -i "encodedcommand\\|enc " sysmon.log
```


56.4 Paso 3: WMI abuse detection

56.4.1 3.1. WMIC patterns

```
grep -i "wmic.*process.*call.*create" sysmon.log
```

56.5 Verificación

Checkpoint	Detección
Encoded PS	Identificado
WMI abuse	Detectado
LOLBin chain	Reconstruido

Chapter 57

Quiz 9: Living Off the Land

Chapter 58

Quiz 9: Living Off the Land

58.0.1 1. Listar

5 LOLBins comunes en Windows.

58.0.2 2. Explicar

Cómo BloodHound ayuda en lateral movement.

58.0.3 3. Identificar

MITRE TID para PowerShell abuse.

58.0.4 4. Verificar

Técnica defensiva contra PsExec.

58.0.5 5. Comando

Escribe el command para enumerar equipos en dominio.

Part X

Unidad 10: Windows Ransomware

Chapter 59

Windows Ransomware

Chapter 60

Unidad 10: Windows Ransomware

60.1 1. Introducción

El ransomware es el **producto final** del pipeline de la dark web. Lockers encriptan archivos y exigen rescate. El modelo Ransomware-as-a-Service (RaaS) democratizó su uso.

60.2 2. Historia del ransomware

Etapas	Año	Característica
Primeros	2005-2012	Encryption simples, envío por email
Modernos	2013-2019	Crypto, C2, evasión
RaaS	2020+	Afiliados, soporte, profit sharing

60.3 3. Técnicas del locker

60.3.1 3.1. Generación de claves

```
// Algoritmo típico de generación
RSA *rsa = RSA_generate_key(2048, RSA_F4, NULL, NULL);
unsigned char aes_key[32];
RAND_bytes(aes_key, 32); // AES-256 key for files
```

60.3.2 3.2. Evasión de recuperación

- **Delete shadow copies:** `vssadmin delete shadows`
- **Exclude system dirs:** Evita que el OS no arranqué
- **Whitelist archivos:** No encripta todo

60.4 4. Caso: REvil/Sodinokibi

El libro compara **dos versiones**:

60.4.1 Versión temprana (2019)

- Encrypt simple con AES
- Whitelist limitada: `C:\Windows`, `bootmgr`
- Payload pequeño (~50KB)
- Sin procesos adicionales

60.4.2 Versión mejorada (2020+)

- **Process hollowing** para inyección
- **Dynamic config** via comando de línea
- **UAC bypass** mejorado
- **Anti-analysis** integrado

60.5 5. Snaffler para reconocimiento

Antes de deployar ransomware, los atacantes buscan datos valiosos:

```
# Enumerar shares accesibles
net view
net view \\target-system
net share

# Snaffler para triage
Snaffler.exe -s -a -o shares.log
# Salida: {Green} (bajo priority) vs {Black} (VM, SQL, passwords)
```

Nota de seguridad: Snaffler es detectado por Defender como no “OPSEC safe”.

60.6 6. Decryptores

Crean cuando: - Claves privadas filtradas (REvil shutdown 2021) - Implementación criptográfica débil - Bug en RNG o key derivation

60.6.1 Ejemplo: Babuk leak

El source code filtrado permitió crear decryptor después de encontrar errores.

60.7 5. Decryptores

Desarrolladores crean decryptores cuando: - Claves privadas filtradas - Implementación débil - Colisiones de RNG

60.8 6. Auto-Evaluación

1. Fases del pipeline de ransomware
2. Técnicas de eliminación de backups
3. Cómo funciona el modelo RaaS

Chapter 61

Laboratorio 10: Análisis de Ransomware Windows

Chapter 62

Laboratorio 10: Análisis de Ransomware Windows

62.1 Objetivo

Analizar técnicas de encriptación en REvil/Sodinokibi sin ejecutar código.

62.2 Paso 1: Identificar rutas excluidas

62.2.1 1.1. Whitelist strings

```
strings ransomware.exe | grep -i -E "(window|system32|boot|whitelist)"
```

62.3 Paso 2: Identificar rutas de eliminación de backups

62.3.1 2.1. Shadow copy deletion

```
strings ransomware.exe | grep -i -E "(vssadmin|shadow|delete|wmic)"
```

62.4 Paso 3: Identificar rutas de exfiltración

62.4.1 3.1. Note drop

```
strings ransomware.exe | grep -i -E "(readme|decrypt|tor.*onion|payment)"
```

62.5 Verificación

Checkpoint	Resultado
Whitelist	Identificado
VSS deletion	Detectado
Note drop	Encontrado

Chapter 63

Quiz 10: Windows Ransomware

Chapter 64

Quiz 10: Windows Ransomware

64.0.1 1. Identificar

Algoritmo típico para generar claves de ransomware.

64.0.2 2. Explicar

Qué hace `vssadmin delete shadows` en ataque.

64.0.3 3. Analizar

Diferencia entre versión temprana y mejorada de REvil.

64.0.4 4. Verificar

Método para identificar ransomware en logs.

64.0.5 5. Comando

Escribe el command para matar procesos específicos.

Part XI

Unidad 11: Linux y ESXi Ransomware

Chapter 65

Linux y ESXi Ransomware

Chapter 66

Unidad 11: Linux y ESXi Ransomware

66.1 1. Introducción

Linux y ESXi son **blancos atractivos** porque: - Menos EDR que Windows - Acceso a VMs completas - Data centers completos comprometidos

66.2 2. ESXi Hypervisor

66.2.1 2.1. Ventajas para atacantes

- VMs completas = más datos
- Sin antivirus tradicional
- Admin tool exposure (ports 80/443/902)

66.2.2 2.2. REvil ESXi variant

66.2.3 3 fases del ataque:

Fase	Acción	Detalles
1. Shutdown	Apaga VMs	<code>vim-cmd</code> <code>vmsvc/power.shutdown</code>
2. Encrypt	Encripta archivos	<code>.vmdk</code> (disco), <code>.vmx</code> (config), <code>.vmsn</code> (snapshot)
3. Exfil	Roba datos	Para doble extorsión (encryption + leak)

66.2.4 Whitelist específico:

/bin, /etc, /usr, /lib, /var/log

No encripta el sistema operativo base para que ESXi arranque.

66.3 3. ALPHV Rust-based

El libro analiza la **implementación Rust**:

66.3.1 3.1. Configuración

Strings encriptados, **whitelisted directories** como /bin y /etc.

66.3.2 3.2. Proceso

1. **Parar servicios**: kill -9 procesos críticos
2. **Procesar archivos**: Encriptar con AES
3. **Eliminar shadow**: Borrar snapshots

66.3.3 3.3. Ventajas Rust

- **Memory safety** sin garbage collector
- **Binarios estáticos** sin dependencias
- **Performance** similar a C/C++
- **Menos detección** por no usar APIs típicas de Windows

66.4 3. ALPHV Rust-based

Las nuevas variantes usan **Go/Rust**: - Binarios estáticos - Menos detección heurística - Código nativo multiplataforma

66.4.1 Características

```
// Whitelisting en Rust
let excluded = vec!["/bin", "/etc", "/usr", "/lib"];
if !excluded.iter().any(|e| path.starts_with(e)) {
    encrypt_file(path);
}
```

66.5 4. Detección en Linux

66.5.1 Syslog monitoring

```
# Auditd para monitorear encriptación masiva  
-a always,exit -F arch=b64 -S open,openat -F exit=-EACCES -k suspicious_file_open
```

66.5.2 Process monitoring

```
# Monitorear procesos sospechosos  
ps aux | grep -E "(openssl|gpg|age)"
```

66.6 5. Auto-Evaluación

1. Diferencias clave Linux vs Windows ransomware
2. Técnicas de detección en ESXi
3. Ventajas del desarrollo en Rust

Chapter 67

Laboratorio 11: Análisis de Ransomware Linux/ESXi

Chapter 68

Laboratorio 11: Análisis de Ransomware Linux/ESXi

68.1 Objetivo

Analizar variantes de ransomware para sistemas Unix sin ejecutar código.

68.2 Paso 1: Identificar paths de ESXi

68.2.1 1.1. Configuración típica

```
strings esxi_ransomware.elf | grep -i -E "(vmfs|vmdk|vmx|vsphere)"
```

68.3 Paso 2: Identificar rutas excluidas

68.3.1 2.1. Whitelist Linux

```
strings ransomware.elf | grep -i -E "(bin|etc|usr|lib|systemd)"
```

68.4 Paso 3: Identificar procesos atacados

68.4.1 3.1. Process killing

```
strings ransomware.elf | grep -i -E "(kill|shutdown|pkill|systemctl)"
```

68.5 Verificación

Checkpoint	Resultado
VMFS paths	Identificado
Whitelist	Detectado
Process kill	Encontrado

Chapter 69

Quiz 11: Linux y ESXi Ransomware

Chapter 70

Quiz 11: Linux y ESXi Ransomware

70.0.1 1. Identificar

Extensión común de archivo de disco de VM.

70.0.2 2. Explicar

Ventaja de Rust para malware.

70.0.3 3. Analizar

Técnica de REvil para VM shutdown.

70.0.4 4. Verificar

Método para monitorear encriptación en Linux.

70.0.5 5. Comando

Escribe el command para listar procesos sospechosos.

Part XII

Unidad 12: Lecciones de la Economía Underground

Chapter 71

Lecciones de la Economía Underground

Chapter 72

Unidad 12: Lecciones de la Economía Underground

72.1 1. Introducción

La dark web no es caos: es un **ecosistema económico** con dinámicas claras. Entender estas dinámicas ayuda a predecir la próxima ola de amenazas.

72.2 2. Modelo económico del underground

72.2.1 2.1. Reactive Development

Los actores reaccionan a: - Parches de seguridad - Operaciones de law enforcement
- Nuevas herramientas de defensa

72.2.2 2.2. Rebranding

Productos criminales: - Cambio de nombre (REvil → Sodinokibi) - Actualización de versiones - Nuevos “vendedores”

72.3 3. Lowered Barriers to Entry

72.3.1 3.1. DIY malware kits

Cualquiera puede comprar: - Phishing kits (\$50-\$500) - Loaders (\$20-\$200) - Ransomware RaaS (30% profit share)

72.3.2 3.2. Tutoriales publicados

La dark web es **educativa**: - Tutoriales de pentesting - Manuales de uso de herramientas - “Cursos” de ciberdelincuencia

72.4 4. Inteligencia Artificial

Aplicaciones emergentes: - **Generación de phishing emails** con LLMs - **Evasión de antivirus** con prompts - **Análisis automático** de vulnerabilidades

72.5 5. Futuro de la ciberseguridad

72.5.1 Tendencias

1. **IA generativa** como arma y defensa
2. **Rust/Go** para malware más eficiente
3. **Ransomware** contra infra crítica
4. **Deepfakes** para ingeniería social

72.5.2 Estrategias defensivas

- Threat hunting proactivo
- Zero-trust architecture
- AI-powered detection
- Supply chain security

72.6 6. Proyecto Final

Analiza un caso real del underground (sin acceder) y escribe: - Herramientas involucradas - Kill chain del ataque - Mitigaciones propuestas - Impacto económico

72.7 7. Auto-Evaluación

1. ¿Qué significa reactive development?
2. Modelo de negocio de Ransomware-as-a-Service
3. Impacto de IA en el underground

Chapter 73

Laboratorio 12: Proyecto Final

Chapter 74

Laboratorio 12: Proyecto Final

74.1 Objetivo

Completar un análisis integral de un caso real del underground y presentar recomendaciones de defensa.

74.2 Paso 1: Selección de caso

74.2.1 1.1. Fuentes permitidas

- Reportes de Symantec/Mandiant
- GitHub: DissectingTheDarkWeb
- Blogposts de investigadores públicos

NO acceder a foros reales

74.3 Paso 2: Análisis del caso

74.3.1 2.1. Kill chain mapping

Fase Kill Chain	Técnica observada	Herramienta usada
1. Reconocimiento		
2. Arma		
3. Entrega		
4. Explotación		
5. Instalación		

Fase Kill Chain	Técnica observada	Herramienta usada
6. C2		
7. Acción		

74.4 Paso 3: Recomendaciones

74.4.1 3.1. Mitigación por fase

Para cada fase identifica: - Señales de detección - Controles preventivos - Respuesta a incidentes

74.5 Entregable

1. Reporte de 2-3 páginas (syllabus + análisis + mitigaciones)
2. Presentación de 5 diapositivas
3. Lista de IoCs recopilados

74.6 Rubrica

Criterio	Excelente	Bueno	Mejorable
Análisis	Kill chain completo	5/7 fases	<5 fases
IoCs	10+ identificados	5-10	<5
Mitigaciones	Al menos 3	1-2	0-1
Presentación	Clara y técnica	Básica	Confusa

Chapter 75

Quiz 12: Lecciones de la Economía Underground

Chapter 76

Quiz 12: Lecciones de la Economía Underground

76.0.1 1. Definir

¿Qué significa reactive development en threat actors?

76.0.2 2. Explicar

Modelo de negocio de Ransomware-as-a-Service.

76.0.3 3. Analizar

Impacto de IA generativa en el underground.

76.0.4 4. Proponer

Una mitigación para futuras amenazas de stealers.

76.0.5 5. Reflexionar

¿Cómo cambia el threat landscape con Rust malware?